Strong authentication and privileged access — Keycloak

Menhir Finance (fictive) · Keycloak — royaume menhir (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-12 13:15**

Auditor sign-off: **pending**
Run: **20261112-130651-keycloak-bench-meta**

Owner: **IT department — IAM team**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-12 13:15, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**4** findings	**0** findings closed and verified	**4** open findings
0 human approvals	**88** sensitive data items masked in evidence	**1 min 34 s** audit duration	**$0.096 *** measured AI cost

Critical: 1 · High: 1 · Medium: 2 · Low: 0

Key messages

- 4 findings across 7 controls: 1 critical, 1 high, 2 medium.
- 4 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-KC-01
Entity	Menhir Finance (fictive)
System	Keycloak — royaume menhir (fournisseur d'identité)
System criticality	Supports critical or important functions (DORA)
Environment	Test Keycloak (fictitious realm)
Owner	IT department — IAM team
Lead auditor	Attest CI (automated run, no human auditor)
Date	2026-11-12 13:15
Framework	DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4

Audited target	Keycloak (open-source identity provider), through the read-only gateway
Work programme	existing catalogue reused · controls/AUD-2026-KC-01.en.json

In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-12; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	STATUS	DUE DATE
F-01	PSI-4.1	MFA enforced for privileged administrator accounts	Critical	Non-compliant	Open	2026-12-12
F-02	PSI-4.2	MFA enforced for users of critical system	High	Non-compliant	Open	2027-02-10
F-03	PSI-4.3	Strong password policy with length and complexity	Medium	Non-compliant	Open	2027-05-11
F-04	PSI-4.5	Idle session timeout limited to 15 minutes	Medium	Non-compliant	Open	2027-05-11
–	PSI-4.4	Account lockout after repeated login failures	Medium	Compliant		
–	PSI-4.6	Logging of administration actions	High	Compliant		
–	PSI-4.7	No generic or shared administrator accounts	High	Compliant		

4. Detailed findings and controls

F-01 **PSI-4.1** **MFA enforced for privileged administrator accounts** — Critical — Non-compliant — Open

CRITERIA

Every account holding the realm role admin has multi-factor authentication configured.

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `["y.tanguy"]`

Expected: `totp=true for every object from GET /api/kc/roles/admin/users`

Checked 4 admin accounts, 1 lack MFA.

PROBABLE CAUSE

MFA was likely left optional in the realm authentication configuration or administrator onboarding process. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

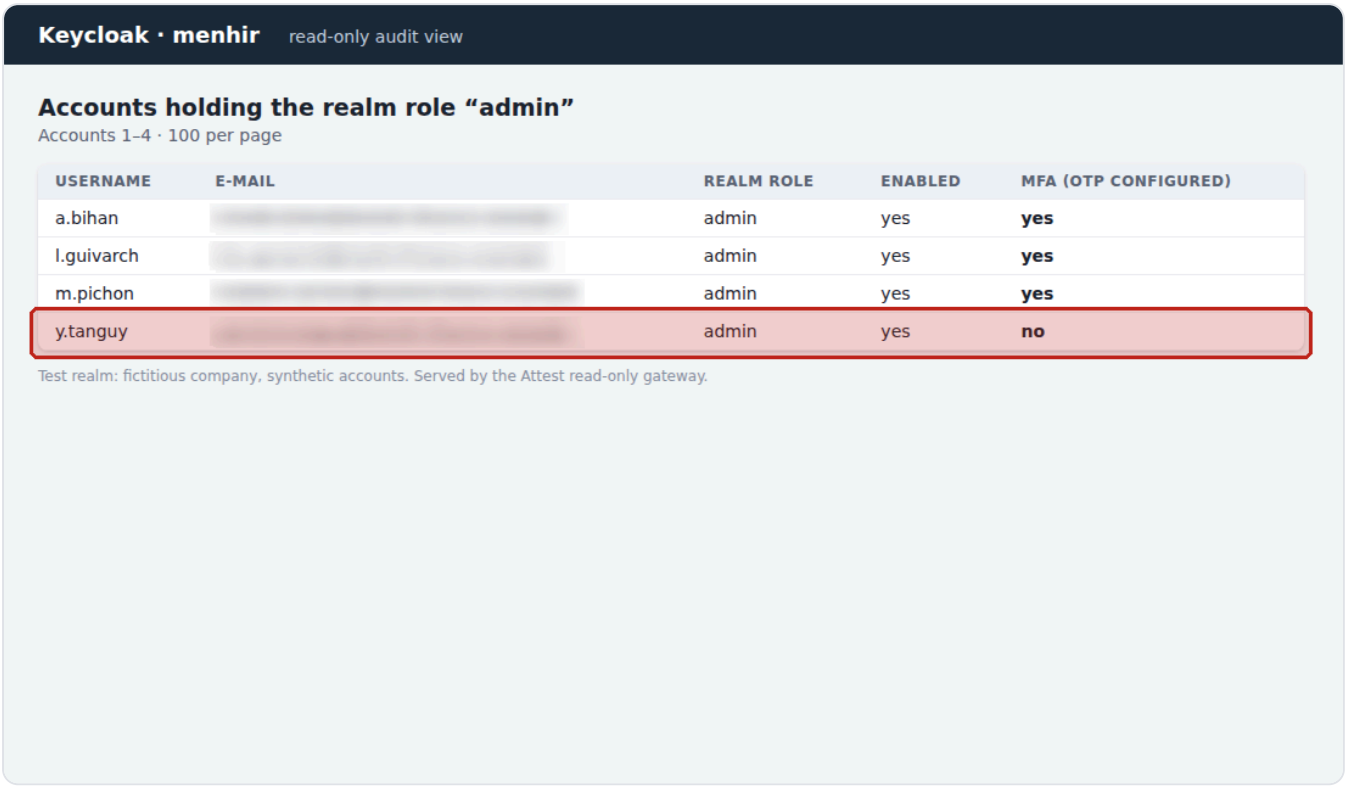
Without MFA, a single stolen privileged password allows full takeover of the identity provider and all connected critical functions.

RECOMMENDATION

Require OTP enrollment for all admin accounts and enforce MFA for the admin authentication flow.

Due date: 2026-12-12 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via paginated GET /api/kc/roles/admin/users and verify totp is true for each account.



At testing — The screenshot corroborates the test. The screenshot shows y.tanguy holding the admin role with MFA marked no, matching the automated failure. · 4/4 sensitive data items masked

`2026-11-12 13:16:07 · SHA-256 a01b2fddf171c244…`

F-02 **PSI-4.2** **MFA enforced for users of critical system** — High — Non-compliant — Open

CRITERIA

Every user account in the realm, which supports critical or important functions, has multi-factor authentication

CONDITION

Observed: `["y.tanguy"]`

Expected: `totp=true for every object from GET`

configured.

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

`/api/kc/users`

1 of 180 users have totp=false.

PROBABLE CAUSE

MFA was likely not made mandatory in the realm authentication flow or user lifecycle process. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Without MFA, password-only authentication exposes critical functions to account takeover by phishing or credential stuffing.

RECOMMENDATION

Require OTP enrollment for all realm users and enforce MFA for the user authentication flow.

Due date: 2027-02-10 · Owner: IT department — IAM team

Test procedure: Retrieve all users via paginated GET /api/kc/users and verify totp is true for each account.

Keycloak · menhir read-only audit view

User accounts

Accounts 101–180 · 100 per page ← previous page

USERNAME	[illegible]AIL	REALM ROLE	ENABLED	MFA (OTP CONFIGURED)
l.uguen	[illegible]	—	yes	**yes**
m.allain	[illegible]	—	yes	**yes**
m.briand	[illegible]	—	yes	**yes**
m.dubois	[illegible]	—	yes	**yes**
m.dupont	[illegible]	—	yes	**yes**
m.floch	[illegible]	—	yes	**yes**
m.garcia	[illegible]	—	yes	**yes**
m.gourmelen	[illegible]	—	yes	**yes**
m.guillou	[illegible]	—	yes	**yes**
m.hamon	[illegible]	—	yes	**yes**
m.jaouen	[illegible]	—	yes	**yes**
m.jaouen2	[illegible]	—	yes	**yes**
m.jegou	[illegible]	—	yes	**yes**
m.jegou2	[illegible]	—	yes	**yes**
m.kervella	[illegible]	—	yes	**yes**
m.lefloch	[illegible]	—	yes	**yes**
m.pichon	[illegible]	admin	yes	**yes**
m.quillien	[illegible]	—	yes	**yes**
n.abgrall	[illegible]	—	yes	**yes**
n.bonnet	[illegible]	—	yes	**yes**
n.dupont	[illegible]	—	yes	**yes**
n.gourmelen	[illegible]	—	yes	**yes**
n.hamon	[illegible]	—	yes	**yes**
n.hamon2	[illegible]	—	yes	**yes**
n.lambert	[illegible]	—	yes	**yes**
n.prigent	[illegible]	—	yes	**yes**
n.raoul	[illegible]	—	yes	**yes**
n.tanguy	[illegible]	—	yes	**yes**
n.vincent	[illegible]	—	yes	**yes**
o.tanguy	[illegible]	—	yes	**yes**
p.bertrand	[illegible]	—	yes	**yes**
p.david	[illegible]	—	yes	**yes**
p.gourmelen	[illegible]	—	yes	**yes**
p.henaff	[illegible]	—	yes	**yes**
p.henaff2	[illegible]	—	yes	**yes**
p.jaouen	[illegible]	—	yes	**yes**
p.le-roux	[illegible]	—	yes	**yes**
p.martin	[illegible]	—	yes	**yes**
p.morvan	[illegible]	—	yes	**yes**
p.petit	[illegible]	—	yes	**yes**
p.quere	[illegible]	—	yes	**yes**
q.girard	[illegible]	—	yes	**yes**
q.kerbrat	[illegible]	—	yes	**yes**
q.kervella	[illegible]	—	yes	**yes**
q.kervella2	[illegible]	—	yes	**yes**
q.vigouroux	[illegible]	—	yes	**yes**
q.vigouroux2	[illegible]	—	yes	**yes**
r.fournier	[illegible]	—	yes	**yes**
r.girard	[illegible]	—	yes	**yes**

r.girard	[redacted]	—	yes	yes
r.gourvennec	[redacted]	—	yes	yes
r.hamon	[redacted]	—	yes	yes
r.lambert	[redacted]	—	yes	yes
r.michel	[redacted]	—	yes	yes
s.cloarec	[redacted]	—	yes	yes
s.floch	[redacted]	—	yes	yes
s.kerjean	[redacted]	—	yes	yes
s.le-goff	[redacted]	—	yes	yes
s.le-meur	[redacted]	—	yes	yes
s.morvan	[redacted]	—	yes	yes
s.richard	[redacted]	—	yes	yes
s.tanguy	[redacted]	—	yes	yes
s.uguen	[redacted]	—	yes	yes
t.briand	[redacted]	—	yes	yes
t.gourmelen	[redacted]	—	yes	yes
t.kerbrat	[redacted]	—	yes	yes
t.le-goff	[redacted]	—	yes	yes
u.le-roux	[redacted]	—	yes	yes
u.le-roux2	[redacted]	—	yes	yes
u.nedelec	[redacted]	—	yes	yes
u.tanguy	[redacted]	—	yes	yes
v.bertrand	[redacted]	—	yes	yes
v.garcia	[redacted]	—	yes	yes
x.gourmelen	[redacted]	—	yes	yes
x.le-bihan	[redacted]	—	yes	yes
x.le-gall	[redacted]	—	yes	yes
y.even	[redacted]	—	yes	yes
y.laurent	[redacted]	—	yes	yes
y.tanguy	[redacted]	admin	yes	no
y.vincent	[redacted]	—	yes	yes
z.lefloch	[redacted]	—	yes	yes

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The screenshot shows user y.tanguy with MFA marked as no, matching the automated failure. · 80/80 sensitive data items masked (78 spotted by the AI, the rest by the deterministic safety net)
`2026-11-12 13:17:22 · SHA-256 468a72b66655441b…`

F-03 PSI-4.3 Strong password policy with length and complexity

Medium · Non-compliant · Open

CRITERIA

The realm passwordPolicy requires minimum length of 12 characters with complexity requirements.

PSI-4.3 · DORA 9(4)(d)

CONDITION

Observed: `length(14)`

Expected: `passwordPolicy contains length(12) or greater and upperCase(1), lowerCase(1), digits(1) and specialChars(1)`

Realm password policy does not satisfy length 12 or greater with upper-case, lower-case, digit and special-character requirements.

PROBABLE CAUSE

The realm password policy was likely left at Keycloak defaults and never hardened to the internal standard. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Weak passwords can be guessed or brute-forced, leading to unauthorized access to critical identity services.

RECOMMENDATION

Set the realm password policy to enforce at least 12 characters with upper-case, lower-case, digit and special-character complexity.

Due date: 2027-05-11 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and parse passwordPolicy to verify length and complexity items are present.

Keycloak · menhir read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**menhir**
enabled	**True**
passwordPolicy	**length(14)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**3**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**1800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The passwordPolicy value is length(14) with no upper-case, lower-case, digit, or special-character rules.

`2026-11-12 13:16:05 · SHA-256 476fddfc104560fd…`

F-04 PSI-4.5 Idle session timeout limited to 15 minutes

Medium · Non-compliant · Open

CRITERIA

Idle SSO sessions expire after at most 15 minutes and idle timeout is not disabled.

PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `1800`

Expected: `ssoSessionIdleTimeout<=900 (seconds) and not disabled or zero`

Realm ssoSessionIdleTimeout is 1800 seconds, exceeding the 900-second limit.

PROBABLE CAUSE

The realm session timeout was likely left at the Keycloak default value exceeding 15 minutes. (AI hypothesis, not tested: to be confirmed with the owner)

RISK

Overly long idle sessions allow session hijacking and unauthorized use of unattended workstations.

RECOMMENDATION

Set the realm idle session timeout to 900 seconds or less.

Due date: 2027-05-11 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and verify ssoSessionIdleTimeout is set to 900 seconds or less.

Keycloak · menhir read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**menhir**
enabled	**True**
passwordPolicy	**length(14)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**3**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**1800**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The screenshot shows ssoSessionIdleTimeout set to 1800 seconds, exceeding the 900-second limit.

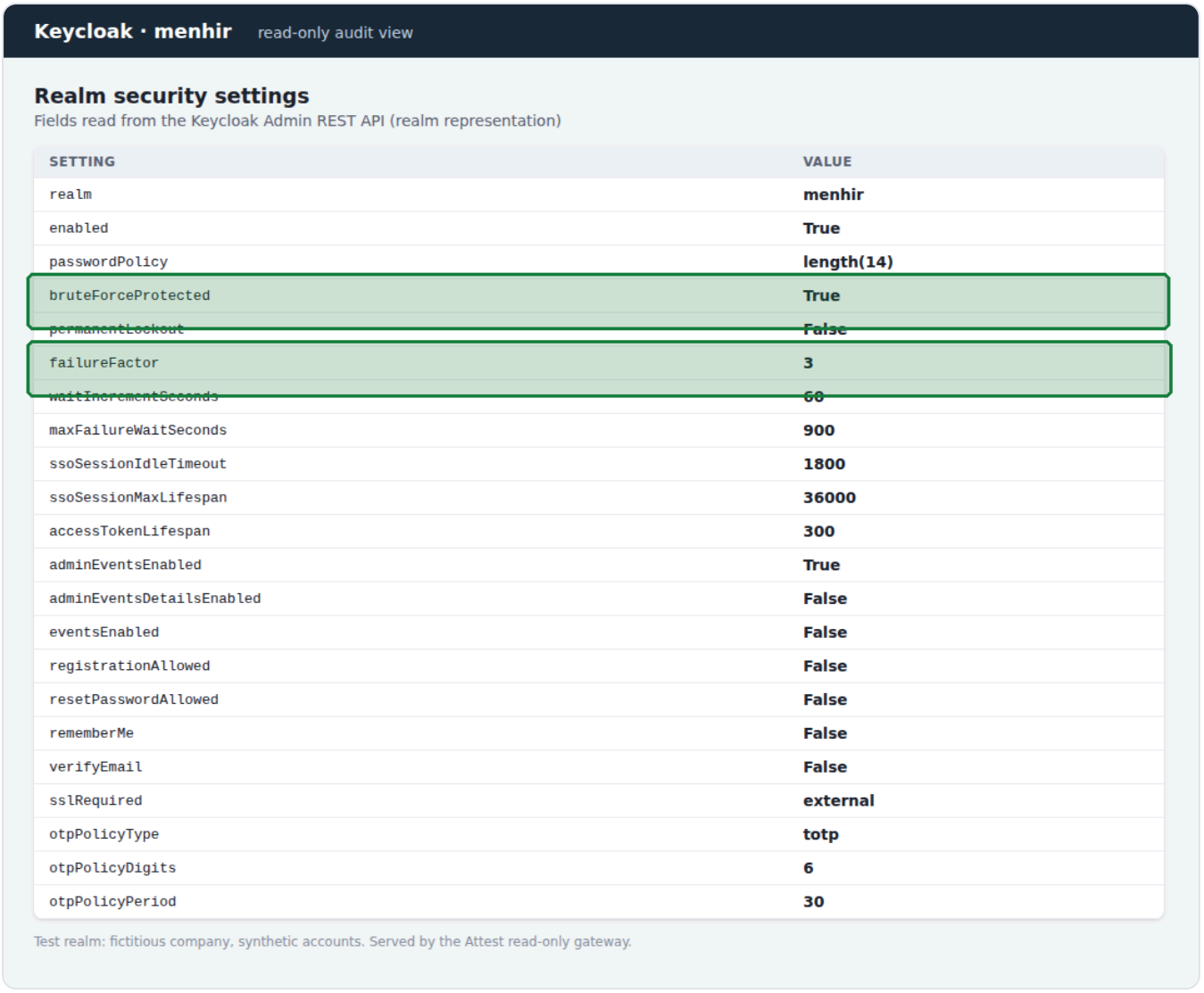
`2026-11-12 13:16:21 · SHA-256 42517bbbc85a39eb…`

PSI-4.4 Account lockout after repeated login failures

Medium · Compliant

Compliant control — Account lockout on repeated login failures is enabled and triggers after at most 5 failures. · DORA 9(4)(c)

Observed: `{"bruteForceProtected": true, "failureFactor": 3}`

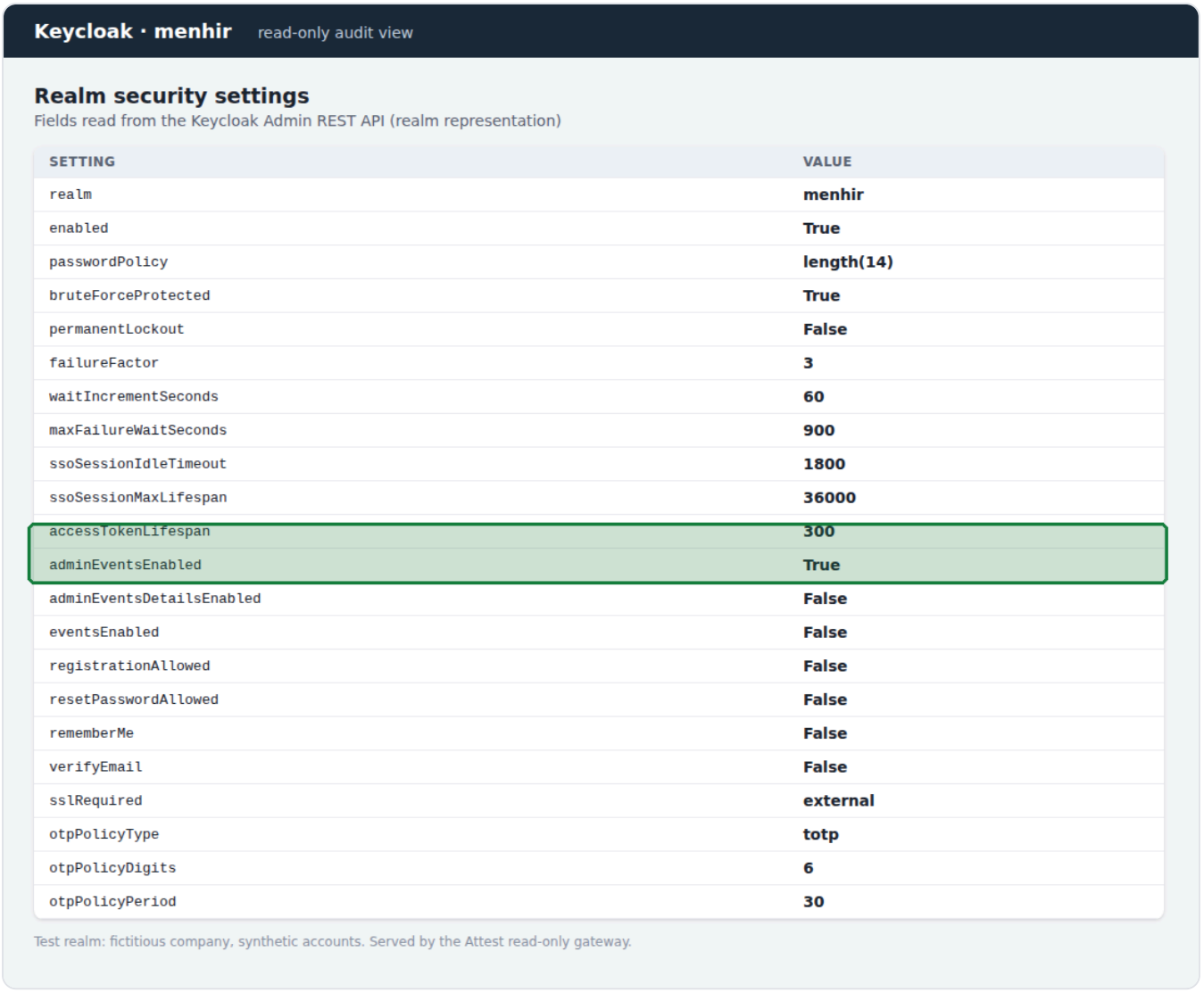


At testing — The screenshot corroborates the test. The screenshot shows bruteForceProtected as True and failureFactor as 3, matching the automated test result.
`2026-11-12 13:16:05 · SHA-256 e77c6e8d35737572…`

PSI-4.6 Logging of administration actions

High Compliant

Compliant control — All administration actions are recorded as admin events in the realm. · RTS 12(2)(c)(i)
Observed: `true`



At testing — The screenshot corroborates the test. The screenshot shows adminEventsEnabled as True, matching the expected value.
`2026-11-12 13:16:25 · SHA-256 192745f750d04ce8…`

PSI-4.7 No generic or shared administrator accounts

High Compliant

Compliant control — No holder of the realm role admin is a generic or shared account, with each admin having a nominative username of form initiale.nom and a personal email. · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)
Observed: `["a.bihan", "l.guivarch", "m.pichon", "y.tanguy"]`



At testing — The screenshot corroborates the test. Screenshot shows four admin accounts with initiale.nom usernames and personal firstname.lastname emails. · 4/4 sensitive data items masked

`2026-11-12 13:16:26 · SHA-256 585653d69cbcf3c8…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · MFA enforced for privileged administrator accounts	c323691e8eb23997 · script library (reused)	Non-compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · MFA enforced for users of critical system	cfb6a114374e16d2 · script library (reused)	Non-compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy with length and complexity	6e6ff63181314ea6 · script library (reused)	Non-compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after repeated login failures	98ece24e4614a2d1 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Idle session timeout limited to 15 minutes	810b3ad6167c2214 · script library (reused)	Non-compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	9169ba76dd0ecf4b · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared administrator accounts	d42aba1d639ac997 · script library (reused)	Compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-12 13:16:07	a01b2fddf171c24492455cd254b651684767cf076e57903e0221b8474ea6bb0c
evidence/C2_before.png	C2 · At testing	2026-11-12 13:17:22	468a72b66655441b4b27de9feb4711d4bd785115ea5264a46ffa1c236a2bd44c
evidence/C3_before.png	C3 · At testing	2026-11-12 13:16:05	476fddfc104560fdecfb5f63766c468ab6393961e95a053e5c2c4b009b5d94a9
evidence/C4_before.png	C4 · At testing	2026-11-12 13:16:05	e77c6e8d35737572b707fa2bdd3bdfa9a64868c297b268659fe6655968430c82
evidence/C5_before.png	C5 · At testing	2026-11-12 13:16:21	42517bbbc85a39eb83dc5443547981db6f75d7f350fa52726133ea705efa98c4
evidence/C6_before.png	C6 · At testing	2026-11-12 13:16:25	192745f750d04ce82b47ffa0d68282fc8cf6c0057757bf06e15dee6c9273ac91
evidence/C7_before.png	C7 · At testing	2026-11-12 13:16:26	585653d69cbcf3c810906cedb38bfae89933c7e8482c66007127c4a1de6ccb45

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	7	15,357	18,149	0	0.0963
`sam-3.1`	12	0	0	12	price not published
Total					**0.0963**

Sensitive data (personal data and secrets) in evidence: 86/88 spotted by Muse Spark + SAM, 88/88 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`6e02bf9a54b089180d89c5e42637f2b4fadf85cf2ec3465197558b22a37bcfed`